超高频 RFID 电子号牌可复制性研究（精简版）

——核心结论、技术要点与防护建议

文档编号	RFID-EPLATE-2026-11-06
版本	v1.2
研究类型	应用安全研究 / 射频识别技术分析（非侵入式、标签层）
申请人 / 主要研究者	匿名（Anonymous）
共同研究者	匿名（Anonymous）
学术讨论	匿名学术讨论组（Anonymous Contributors）
完成日期	2026-11-06
开源地址	https://github.com/********/********
许可	CC BY-NC-ND 4.0（署名—非商业性使用—禁止演绎）

严禁商用 · 严禁贩卖 · 严禁未授权通行

ACADEMIC RESEARCH ONLY — NOT FOR COMMERCIAL USE, NOT FOR RESALE

科学无罪 · 数据无罪 · 开源无罪

严禁商用 · 严禁贩卖 · 严禁未授权通行

本文为学术研究与防御性安全评估文档，全部标签数据均已脱敏，不含任何真实号牌的 EPC、TID、密钥或可复现的通行凭证。

摘要

本文以校园电动自行车数字化号牌为对象，分析其无源超高频（UHF, 860–960 MHz）EPC Gen2 标识模型与门禁判定逻辑，讨论"标识字段可复制性"这一安全属性。

结论是：当系统仅以 EPC 作为身份判据、且标签未启用密码学认证时，标签层复制在工程上属于低门槛、低成本、高一致性的操作。其根因不是射频技术缺陷，而是 **Gen2 协议不提供标签与读写器之间的密码学认证**，以及系统侧缺少多因子核验。



图 1　校园电动自行车数字化号牌实物。号码区域已做实色遮挡，二维码已模糊处理。

1 研究边界

讨论范围	明确排除
标识字段能否被快速、正确、可重复地转移并保持一致	数据保存与持久化方案
标签内存分区结构与读写一致性判定	任何真实标签数据的采集与分享
可复制性的成因与系统级防护	后台系统入侵、目标系统细节、成品通行方案

讨论范围	明确排除
三级克隆模型与风险分级	号牌版面与印刷制版资料

2 技术要点

2.1 标签内存四区

分区	内容	典型长度	可写性	与复制的关系
Reserved	Kill Password + Access Password	64 bit	可写（需权限）	默认常为全 0
EPC	CRC-16 + PC 字 + EPC 号	128 bit 起	多数芯片可写	系统身份判据，主要复制目标
TID	类别 + 厂商 + 型号 + 序列号	32/48/64 bit	出厂只读	唯一性锚点
User	用户自定义	0–512 bit	可写	视系统设计而定

EPC 区并非整块字符串，而是 `CRC-16 | PC | EPC` 三段拼接。PC 字高 5 位编码 EPC 长度，长度、校验、PC 三者必须自洽——这是"正确复制"与"表面复制"的分水岭。

2.2 三级克隆模型

等级	复制对象	门槛	能否通过 EPC-only 校验	能否通过 EPC+TID 校验
L1	仅 EPC 字段	极低	能	否
L2	EPC + TID	高	能	能
L3	物理层指纹	极高	能	视检测手段

本文验证的是 L1 级——成本最低、门槛最低，也是现实中风险最高的一级。

2.3 根因

- 协议无认证：Inventory 与 Read 不需要任何身份认证，标签无法区分合法读写器与旁观者；
- EPC 可写：空白卡出厂即开放写入，无需破解；
- 判定单因子：系统只认 EPC，不认芯片身份；
- 32 位口令明文传输且常为默认值，不构成有效保护。

3 验证结论

1. 号牌标签符合 Gen2 标准结构，EPC 长度 96 bit，PC 自洽、CRC 正确，可被通用读写器完整读取。
2. 同规格空白标签 EPC 区可写，写入后回读一致，结构自洽，"快速且正确"的复制在标签层可行。
3. 复制标签的 TID 与原标签不同，因此 EPC+TID 联合校验可使 L1 克隆失效。
4. 复制卡的射频性能与原卡接近但不等价，差异来自天线几何与介质环境，与数据内容无关。

一致性判定采用五项指标：字段完整性、PC 自洽、CRC 正确、回读一致、性能偏移（建议 ≤ 20%）。

4 防护建议

层级	措施	有效性
标签层	发卡后 PermaLock(EPC)，杜绝改写	高（可阻断 L1）
标签层	选用支持 Gen2v2 / AES-128 认证的芯片	高
平台层	EPC + TID 双因子绑定并校验	高
平台层	同 EPC 异 TID 告警、时空矛盾拦截、频次限制	高
读写器层	最小必要功率、天线朝向控制、RSSI 记录	中
物理层	全息防伪、流水号与 EPC 双向绑定	中
管理层	发卡留痕、定期盘点、即时吊销	中

5 结论

标签可复制只说明凭证可复制，不等于系统必然被攻破；风险取决于系统信任什么、记录了什么、能否发现异常。低成本、可立即实施的防护是 **PermaLock(EPC) 与 EPC+TID 双因子绑定**。

本文只讨论标识字段的转移与一致性，**不讨论数据保存、不分享任何数据、不提供任何可用于非授权通行的方案**。完整论证、实验设计、风险矩阵与参考文献见完整版。

> 开源地址：https://github.com/********/********
> 科学无罪 · 数据无罪 · 开源无罪